

Security Rubric-Check Feedbackrapport

OpenMRS Legacy UI Module v1.20.0 · NEN-7510:2024-2

Pre-inlevering dubbelcheck · Gegenereerd: 17 June 2026

Module: legacyui-audit · Repo: Polen-Fan-Club/legacyui-audit (private) · Vertrouwelijk

1. Samenvatting per criterium

Criterium	Max	Status	Niveau	Korte bevinding
SA — Security audit (wetgeving & normen)	20	■■	Goed*	SA.7+SA.8 voldaan; RAG-status ontbreekt; TM heeft 4/5 vereiste NEN-controls
SP — Secure pipelines (wetgeving & normen)	15	■■	Voldoende	OTAP ingericht maar environments niet getriggerd; Secret Scanning ontbreekt
AU — Advies updates (SBOM, CVE en CVSS)	15	■■	Voldoende	SBOM ■, concreet advies ■; Z-CERT ontbreekt; FP-categorieën gedeeltelijk
CR — Security code review & kwetsbaarheden	15	■■	Voldoende	Tooling ■, NEN-controls ■; CWE-referenties ontbreken; threat model-koppeling impliciet
PT — Penetration tests (aantonen kwetsbaarheden)	15	■	Goed	Volledig: OWASP-methodiek, 6 bevindingen, hertestbewijs, reproduceerbaar
MV — Mitigatie & validatie verbeteringen	20	■■	Voldoende	4/6 fixes opgelost + hertests; kwantitatief voor/na security ontbreekt; AI-tooling alleen voor PoC
TOTAAL	100		~71/100	Ingeschatte totaalscore: ~71 punten. Voldoende op alle criteria; Goed op SA en PT.

* SA scoort Goed op inhoud en herleidbaarheid, maar de traceability matrix dekt slechts 4/5 vereiste NEN-controls en de executive summary mist een expliciete RAG-label. Bij strikte beoordeling van SA.2/SA.3/SA.4: borderline Goed.

2. Kritieke ontbrekende items (■)

Één enkel ontbrekend item gevonden. Geen rubricdrempel geblokkeerd op 'Onvoldoende'.

Check-ID	Omschrijving	Verwacht pad / locatie	Blokkeert
SP.3	Secret Scanning actief: GitHub native Secret Scanning vereist GHAS (niet beschikbaar). Geen compenserende workflow of tooling gevonden. Het mini-complianceverslag behandelt GHAS-afwezigheid voor CodeQL/Dependency Review, maar noemt Secret Scanning niet als expliciet punt.	<code>.github/workflows/secret-scan.yml</code> of equivalent; of bewuste compensatie gedocumenteerd in <code>mini-complianceverslag.md §2</code>	SP.12 Goed-drempel

3. Gedeeltelijke items (■ ■)

Check-ID	Wat er al is	Wat specifiek ontbreekt	Blokkeert drempel
SA.2	docs/traceability-matrix.md aanwezig; kolommen functioneel compleet (bron, commit hash, PR#, hertestpad, NEN)	Slechts 4 NEN-controls (8.3, 8.5, 8.9, 8.15). Rubric vereist ≥5. Ontbreekt: 8.28, 8.8, 8.25, 5.35/5.36. Voeg minimaal één rij toe voor SAST (8.28) of kwetsbaarhedenbeheer (8.8) met verifieerbaar artefact.	SA Goed (SA.8)
SA.3	8.15 (logging) aanwezig in TM met commit-hash en hertestpad	8.28 (SAST-bevindingen/veilig coderen), 8.8 (Dependabot/Snyk), 8.25 (pipeline/ontwikkelcyclus), 5.35/5.36 (audit/naleving) NIET in TM. Ze worden elders genoemd (snyk-sca.yml r.8-9) maar zijn niet met verifieerbaar bewijs-artefact opgenomen.	SA.3 Voldoende
SA.4	docs/executive-summary.md heeft management-taal ■, no onnodige technische details ■, top-3 risico's ■, roadmap ■	Geen expliciete RAG-status (Rood/Amber/Groen). De status is beschrijvend ("gedeeltelijk compliant", "niet productierijp") maar geen kleurlabel. Voeg één regel toe: "Algeheel oordeel: AMBER — aantoonbaar veiliger, significant restrisico".	SA Goed (SA.4)
SP.6	3 GitHub Environments aangemaakt; prod heeft protection rule (required reviewer); docker-compose.yml met OTAP-profielen	Environments nog NIET gekoppeld aan een deploy-workflow — protection rule wordt nog niet getriggerd (mini-complianceverslag.md §3 M5 vermeldt dit zelf). Activeer de protection rule door de deploy-job de environment te laten specificeren.	SP.12 Goed

SP.12	pentestplan.md §1: "Geen productiedata — OpenMRS demo-data (NEN-7510 8.33, AVG art. 5)" voor testomgeving	Geen expliciete verantwoording van niet-herleidbare data per OTAP-omgeving als zelfstandig document of sectie. Vereist: aantoonbaar gedocumenteerde keuze voor elk van de O/T/A/P-omgevingen (bijv. als §6 in mini-complianceverslag.md).	SP.12 Goed
AU.2	docs/sbom-supply-chain.md: tabel met pakket/vulns/hoogste/upgrade/advises; docs/risk-assessment-report.md §3b heeft zelfde tabel	Versienummers en licentie-informatie NIET per component opgenomen. Rubric verwacht: component versie licentie bekende CVE's status. De versie+licentie-info staat in het CI-artifact (sbom.cdx.json) maar niet in de analyse-documentatie.	AU.9 Goed
AU.6	Dependabot alerts actief; wekelijkse Snyk-scan (cron maandag); sbom-supply-chain.md beschrijft monitoring-aanpak	Geen Z-CERT-referentie of equivalent formeel leveranciersmonitoringmechanisme gedocumenteerd (NEN-7510 5.22). Voeg toe aan sbom-supply-chain.md: verwijst naar Z-CERT (zorg-CERT) of CVE-NVD feed als aanvullend monitoringkanaal voor derde partijen.	AU.9 Goed
AU.7	docs/false-positive-beleid.md: Fix/Accept/False positive/Defer met verplichte onderbouwing; .snyk policyfile met reason+expires; Dependabot dismiss met reden	Specifieke FP-categorieën uit de rubric NIET expliciet opgesomd: unreachable code, parameterized queries, sanitization buiten scope, component niet in runtime, vendor heeft al gepatcht. Voeg als §3 "Categorieën van false positives" toe aan false-positive-beleid.md.	AU.9 Goed
CR.2	pentestplan.md: finding-ID ■, beschrijving ■, CVSS v3.1 ■, aangetaste code-locatie (file:line) ■, NEN-control ■, OWASP-categorie (A01/A07/A09/A05) ■	CWE-referentie ONTBREEKT per bevinding. Rubric vereist CWE-referentie naast finding-ID. Voeg toe per bevinding: CWE-287 (auth failure), CWE-778 (insufficient logging), CWE-200 (info disclosure), CWE-307 (brute force) etc.	CR.8 Goed
CR.3	OWASP Testing Guide ■, NEN-7510:2024-2 ■, AVG art. 5 ■ als bronnen; CVSS-scores zelf bepaald via FIRST-calculator ■	NVD en CWE-database niet expliciet als bron geciteerd per bevinding. Z-CERT niet vermeld. Voeg bij elke bevinding een "Bronnen:"-regel toe met NVD-link of CWE-link naast de OWASP-categorie.	CR.8 Goed

CR.6	docs/audit-methodologie.md beschrijft 4 onderzoekssporen (gap-analyse, attack surface, pentest, SCA) als complementair; threatmodel-v2.pdf + attack-surface-samenvatting.md aanwezig met STRIDE-koppeling	Bevindingssecties in pentestplan.md en gap-analyse verwijzen NIET expliciet terug naar het threat model of STRIDE-categorieën. Voeg per bevinding een "Threat model ref:"-veld toe dat verwijst naar de relevante STRIDE-categorie (bijv. "S — Spoofing (threat model §3.1)").	CR.8 Goed
MV.3	docs/conclusie-advies.md: kwalitatief voor/na per NEN-control; pentestplan.md §5: hertest-resultaten per bevinding	Kwantitatief voor/na-vergelijking ONTBREEKT: geen voor/na Snyk-scan met minder CVE-telling, geen CodeQL-findings-vergelijking, geen SonarCloud-kwaliteitspoort. Baseline-keuze (niet patchen voor analyse) is de oorzaak maar maakt kwantitatief meten moeilijk — dit verdient expliciete toelichting.	MV.10 Goed
MV.6	JaCoCo CI-artifact `jacoco-coverage` aanwezig (ci.yml if-no-files-found: error); docs/validatie.md heeft coverage-% voor FormatTag refactor (onderhoudbaarheid)	Coverage-% voor security-relevante klassen NIET apart onderbouwd. AuditLoggingTest en LogoutServletAuditTest zijn aanwezig maar het bijbehorende coverage-%-getal voor LoginServlet, UserFormController etc. staat niet in de securitydocumentatie. Voeg een tabel toe: klasse vóór coverage ná coverage bron: jacoco-coverage artifact.	MV.10 Goed
MV.7	docs/realisatie-poc.md §5: uitgebreide AI-toolingverantwoording (Claude Code) voor de FormatTag-refactor met kritische reflectie ■	Voor de SECURITY-auditactiviteiten (gap-analyse, pentestplan, backlog) is GEEN AI-toolingverantwoording opgenomen. Rubric vraagt dit voor alle realisatiewerk. Voeg een §"AI-toolinggebruik in de security-audit" toe aan risico-bevindingen.md of conclusie-advies.md.	MV.10 Goed
MV.8	Kwalitatief: "10 events nu gelogd" ■; hertestbewijs per bevinding ■; reproduceerbare repro-*.sh scripts ■	Kwantitatieve vóór/na-meting voor security ONTBREEKT: geen "Snyk: 128 vulns → X na patch", geen "CodeQL: Y findings → Z na fix". Alleen de FormatTag-refactor heeft kwantitatieve metriecken (CC 13→4). Voeg minimaal één concrete security metric toe (bijv. logging-coverage per klasse voor/na).	MV.10 Goed

4. Sterke punten (■)

Check	Bevinding	Bestandspad (bewijs)	Koppeling rubric
SA.1	Modulair maar compleet auditrapport: executive summary, scope, methodologie, 6 bevindingen met CVSS, security backlog, kostenraming (€4.560 / 9,5 dag), risicoacceptatie, bijlagen-index (A–W)	docs/executive-summary.md docs/bijlagen.md docs/risk-assessment-report.md	SA.7 Voldoende SA.8 Goed
SA.5	≥6 NEN-7510:2024-2 controls gekoppeld aan bevindingen: 8.3 (IP-binding), 8.5 (auth), 8.15 (logging), 8.9 (info-disclosure), 8.8 (dep-vulns), 8.29 (hertest)	docs/pentestplan.md bevindingen #1-#6 docs/gap-analyse-NEN7510.md docs/risk-assessment-report.md	SA.5 ■
SA.6	Prioritering expliciet gemotiveerd via risicocriteria variant B (grenswaarde ≥10 bij patiëntdata). Acceptatiebeslissingen #2 en #4 expliciet onderbouwd met CVSS 6.5 en 5.3 < drempel van 10.	docs/risicocriteria.md docs/pentestplan.md §4 docs/risico-bevindingen.md	SA.6 ■ SA.8 Goed
SP.2	CodeQL SAST actief: weekly + PR/push trigger, SARIF als CI-artifact. Bewuste keuze upload:false (GHAS niet beschikbaar) gedocumenteerd en verantwoord in mini-complianceverslag.md M2.	.github/workflows/codeql.yml docs/mini-complianceverslag.md §3 M2	SP.2 ■ SP.11 Voldoende
SP.5 AU.1	SBOM (CycloneDX 1.5, ~100 componenten) gegenereerd bij elke CI-build als artifact `sbom-cyclonedx`. Fallback-logica voor outputDirectory-variantie. if-no-files-found: error borgt aanwezigheid.	.github/workflows/ci.yml r.52-79 docs/mini-complianceverslag.md M1	SP.5 ■ AU.1 ■ AU.8 Voldoende
SP.9	mini-complianceverslag.md §5 heeft formeel bewijsregister (7 rijen) met kolommen: Bewijs Vindplaats Verifieerbaar via. Elk item is onafhankelijk verifieerbaar.	docs/mini-complianceverslag.md §5	SP.9 ■ SP.11 Voldoende
AU.4	CVSS-scores zelf bepaald en geverifieerd via FIRST-calculator (pentestplan.md voetnoot §5). Contextuele aanpassing gedocumenteerd: finding #3 — CVSS onderschat auditability-verlies; finding #5 — CVSS secundair, risicocriteria leidend.	docs/pentestplan.md §5 noten docs/risico-bevindingen.md	AU.4 ■

AU.5	Concreet patchadvies per kwetsbaar pakket: xstream (upgraden, RCE), commons-fileupload (prioriteit), log4j 1.x (migreren, niet patchen, EOL), spring-* (bumpen + build-impact testen). Gevaren eerlijk gedocumenteerd (build breekt op sommige bumps).	docs/sbom-supply-chain.md §2 docs/risk-assessment-report.md §3b+§5	AU.5 ■ AU.8 Voldoende
CR.4	Onoplosbare risico's expliciet geaccepteerd met onderbouwing: #2 brute-force (CVSS 6.5 < 10, drempel aanwezig, bewijs T2/hertest/), #4 gebruikersenumeratie (CVSS 5.3 < 10, signaal smal, core-afhankelijkheid). Herbeoordeling bij volgende scan vastgelegd.	docs/pentestplan.md bevindingen #2+#4 docs/risico-bevindingen.md	CR.4 ■ CR.7 Voldoende
CR.5	Threat model aanwezig als PDF (threatmodel-v2.pdf) + attack-surface-samenvatting.md met STRIDE-koppeling. C4-diagrammen in c4-diagrammen.pdf. Risicomatrix in risicomatrix.pdf.	docs/pdf/threatmodel-v2.pdf docs/pdf/c4-diagrammen.pdf docs/pdf/risicomatrix.pdf docs/attack-surface-samenvatting.md	CR.5 ■
PT.1–PT.9	Volledigste criterium: OWASP Testing Guide 5 fasen, 6 bevindingen met ID/ernst/CVSS/NEN/besluit, hertestbewijs (T1/T3/T5/T6/hertest/), reproduceerbare repro-*.sh scripts, resultatenoverzicht §5, besluitkader §4, weerlegde hypothese T4 gedocumenteerd.	docs/pentestplan.md docs/pentest-bewijs/T1-T6/ docs/pentest-omgeving/	PT.8 Voldoende PT.9 Goed
MV.1 MV.2	4 van 6 pentest-bevindingen opgelost met herleidbare commits en hertests: 7e1c705 (IP-binding), c693cb2 (logging), 9ab74ee (reset-flow), 9c14af3 (info disclosure), 0421a10 (WARN-niveau). Alle via PR #50 en PR #52 — verifieerbaar in git-history.	docs/traceability-matrix.md docs/pentest-bewijs/T*/hertest/	MV.1 ■ MV.2 ■ MV.9 Voldoende
MV.4 MV.5	Audit-logging geïmplementeerd in alle 5 vereiste controllers (LoginServlet, LogoutServlet, UserFormController, ChangePasswordFormController, ForgotPasswordFormController). 10 security-event-categorieën op WARN. Wachtwoord NIET in logs (geverifieerd hertest T3). Unit tests: AuditLoggingTest.java + LogoutServletAuditTest.java.	omod/src/test/.../AuditLoggingTest.java omod/src/test/.../LogoutServletAuditTest.java docs/pentestplan.md §5 bevinding #3 hertest	MV.4 ■ MV.5 ■ MV.9 Voldoende

MV.7 (PoC)	AI-toolingverantwoording voor FormatTag PoC is uitstekend: Claude Code als uitvoerder, 4 gecontroleerde fasen, kritische reflectie op wat NIET aan de tool overgelaten is, verificatie van CC-schatting tegen werkelijke meting (CC tool zei ≈ 2 , werkelijk 4).	docs/realisatie-poc.md §5	MV.7 (PoC) ■ MV.9 Voldoende
------------	--	---	--------------------------------

5. Rubric-scoreinschatting

Criterium	Max	Vol d.	Ingesc hat	Niveau	Motivatie
SA — Security audit	20	11	16	Goed*	SA.7+SA.8 voldaan. -4 voor ontbrekende RAG (SA.4) en onvolledige TM-NEN-dekking (SA.2/SA.3). Inhoud is grondig en herleidbaar.
SP — Secure pipelines	15	8	10	Voldoende	SP.11 behaald met voorbehoud (OTAP ingericht maar environments niet getriggerd). SP.12 niet bereikt (niet-herleidbare data per OTAP onvolledig). Secret Scanning ontbreekt (SP.3).
AU — Advies updates	15	8	10	Voldoende	AU.8 voldaan (SBOM + onderbouwd advies). AU.9 niet bereikt: Z-CERT (5.22) ontbreekt, FP-categorieën onvolledig, versie/licentie niet per component.
CR — Security code review	15	9	10	Voldoende	CR.7 voldaan. CR.8 borderline: diepgang ■, relatie kwetsbaarheden-systeemgebruik ■ (CIA/BIV impact in bevindingen), maar CWE-referenties ontbreken en threat model-link is impliciet.
PT — Penetration tests	15	8	13	Goed	PT.8+PT.9 voldaan. Alle 9 checks volledig groen. Kleine aftrek: tijdlijn niet als expliciete datum/periode in het plan opgenomen.
MV — Mitigatie & validatie	20	11	12	Voldoende	MV.9 voldaan (4/6 fixes + tests + realisatie). MV.10 niet bereikt: kwantitatief voor/na security ontbreekt, AI-tooling voor securitywerk niet gedocumenteerd, coverage-% per klasse niet onderbouwd.
TOTAAL	100	55	71	Voldoende	Score valt boven drempel Voldoende. Goed bereikt op SA (inhoud grondig) en PT (volledig). SP/AU/CR/MV op Voldoende.

* SA-inschatting 16/20: indien de beoordelaar strikte interpretatie toepast op SA.2/SA.3 (traceability matrix heeft 4 i.p.v. ≥5 NEN-controls; 8.28/8.8/8.25/5.35-5.36 missen bewijs-artefact) kan dit tot Voldoende (11 punten) dalen. Totaalinschatting in dat geval: ~66/100 — nog steeds Voldoende.

6. Traceability-check NEN-7510-controls

Expliciete controle: zijn de 5 aanbevolen NEN-7510:2024-2 controls gedekt in de traceability matrix (docs/traceability-matrix.md) met een verifieerbaar bewijs-artefact?

Control	In TM?	Bewijs-artefact (TM)	Volledigheid
---------	--------	----------------------	--------------

8.28 — Veilig coderen (SAST)	■ Niet	CodeQL SARIF-artifact en Snyk-rapport bestaan als CI-artefact, maar zijn NIET als rij opgenomen in de traceability matrix. snyk-sca.yml r.8 verwijst naar 8.8 (niet 8.28). Gap-analyse verwijst naar 8.28 impliciet via veilig-coderen-bevindingen.	ONTBREEKT in TM. Aanwezig in CI maar niet herleidbaar als TM-rij.
8.8 — Kwetsbaarheid enbeheer (Dependabot/Snyk)	■ Niet	Snyk SCA-rapport als CI-artifact (snyk-sca.yml). Dependabot actief (PR's #10-14). sbom-supply-chain.md NEN-koppeling 8.8 aanwezig. Maar GEEN TM-rij met commit/PR/bewijs-artefact.	ONTBREEKT in TM. Elders gedocumenteerd maar niet herleidbaar als TM-rij met artefact.
8.15 — Logregistratie (logging-implementatie)	■ Ja	TM rij #3: commit c693cb2 (PR #50) + 0421a10 (PR #52). Hertest: docs/pentest-bewijs/T3/hertest/ + AuditLoggingTest/LogoutServletAuditTest. Volledig herleidbaar.	VOLLEDIG: commit hash ■, PR ■, hertest ■, test-klassen ■
8.25 — Beveiliging in de ontwikkelcyclus (pipeline)	■ Niet	cicd-risico-evaluatie.md beschrijft pipeline-risico's. mini-complianceverslag.md beschrijft M1-M7. Maar geen TM-rij voor 8.25 met verifieerbaar bewijs-artefact (commit, PR, scan-datum).	ONTBREEKT in TM. Gedocumenteerd in ci/cd-docs maar niet als TM-bewijs-rij.
5.35/5.36 — Naleving/beoordeling (het rapport zelf)	■ Niet	Het auditrapport zelf IS de naleving/beoordelings-controle (5.35 = beoordeling naleving, 5.36 = review van beleid). docs/bijlagen.md indexeert alle documenten. Maar geen expliciete TM-rij die 5.35/5.36 als control met bewijs opneemt.	ONTBREEKT in TM. Impliciet: rapport = bewijs, maar niet als TM-rij met artefact.

Traceability Matrix Status: INCOMPLEET — 1/5 aanbevolen controls gedekt met verifieerbaar bewijs-artefact (alleen 8.15 is volledig). 8.28, 8.8, 8.25 en 5.35/5.36 zijn elders gedocumenteerd maar ontbreken als TM-rij met commit-hash of scan-artefact.

Aanbeveling: voeg 4 rijen toe aan docs/traceability-matrix.md: (a) 8.28: CodeQL-run datum + SARIF-artefact als 'na'; (b) 8.8: Snyk-rapport CI-artefact + Dependabot PR #10-14 als 'aanpassing'; (c) 8.25: mini-complianceverslag commit + branch protection ruleset als 'bewijs'; (d) 5.35: docs/audit-methodologie.md + bijlagen-index als 'bewijs-artefact'.

7. Genummerde actielijst (gesorteerd op urgentie)

#	Criterium / Check	Actie	Verwacht pad	Prioriteit
1	SA — SA.2, SA.3 (traceability matrix)	Voeg 4 rijen toe aan de traceability matrix voor 8.28 (SAST), 8.8 (Dependabot/Snyk), 8.25 (pipeline), 5.35/5.36 (audit-naleving). Elke rij moet een verifieerbaar bewijs-artefact hebben (commit hash, CI-artefact naam, of scan-datum).	docs/traceability-matrix.md	KRITIEK
2	SA — SA.4 (executive summary)	Voeg een expliciete RAG-status (Rood/Amber/Groen) toe aan de executive summary. Aanbeveling: "Algeheel beveiligingsoordeel: AMBER — module is aantoonbaar veiliger geworden maar niet productierijp voor een zorgomgeving zonder de geprioriteerde vervolgstappen."	docs/executive-summary.md (eerste alinea of afzonderlijk blok)	KRITIEK
3	MV — MV.7 (AI-tooling securitywerk)	Voeg een sectie "AI-toolinggebruik in de security-audit" toe (analoog aan realisatie-poc.md §5). Beschrijf welke tools gebruikt zijn voor gap-analyse/pentestplan/backlog, wat handmatig gedaan is, en een kritische reflectie. Ontbreekt volledig voor securityactiviteiten.	docs/conclusie-advies.md of docs/audit-methodologie.md (nieuwe §)	HOOG
4	CR — CR.2 (CWE-referenties)	Voeg een CWE-referentie toe per bevinding in pentestplan.md. Minimaal: #1 CWE-613/CWE-384, #2 CWE-307, #3 CWE-778, #4 CWE-204, #5 CWE-640, #6 CWE-200. CWE is een standaardreferentie die bij OWASP-categorieën hoort.	docs/pentestplan.md (bevindingsblokken #1-#6)	HOOG
5	MV — MV.8 (kwantitatief voor/na)	Voeg een kwantitatieve voor/na-meting toe voor security. Minimaal één concrete meting: bijv. logging-testcoverage per klasse (LoginServlet: X% → Y%) uit het JaCoCo-artifact, of het aantal gelokte SAST-regels voor/na via CodeQL-run vergelijking.	docs/conclusie-advies.md § "Aantoonbaar verlaagd risico" of docs/validatie.md (security-sectie)	HOOG
6	SP — SP.3 (Secret Scanning)	Documenteer Secret Scanning-positie expliciet. Ofwel: (a) activeer een alternatief zoals truffleHog of gitleaks als workflow, OF (b) voeg in mini-complianceverslag.md M8 toe: "Secret Scanning: GHAS vereist, niet beschikbaar. Compenserende maatregel: .gitignore + pre-commit hook + commit 10f9a4a als bewijs." Met expliciet comply-or-explain.	.github/workflows/secret-scan.yml of docs/mini-compliance-verslag.md §2 M8	HOOG

7	AU — AU.6 (Z-CERT / 5.22)	Voeg een verwijzing naar Z-CERT of NVD-CVE-feed toe als formeel leveranciersmonitoringmechanisme (NEN-7510 5.22). Minimaal één alinea in sbom-supply-chain.md: "Monitoring derde partijen: Z-CERT (z-cert.nl) voor zorg-specifieke CVE-alerts + wekelijkse Snyk-scan (cron maandag)."	docs/sbom-supply-chain.md (nieuwe §"Monitoring leveranciers")	MIDDEL
8	AU — AU.7 (FP-categorieën)	Voeg §3 "Categorieën van false positives" toe aan false-positive-beleid.md met de 5 vereiste categorieën: (1) unreachable code, (2) parameterized queries, (3) sanitization buiten scope, (4) component niet in runtime, (5) vendor heeft al gepatcht. Per categorie: definitie + voorbeeldcriterium voor toewijzing.	docs/false-positive-beleid.md (nieuwe §3)	MIDDEL
9	SP — SP.6 (Environments activeren)	Koppel de drie GitHub Environments aan een deploy-workflow zodat de protection rule (required reviewer op prod) daadwerkelijk triggert. Voeg .github/workflows/deploy.yml toe die per environment de juiste deployment-stap uitvoert en de environment:name-directief bevat.	.github/workflows/deploy.yml (nieuw, verwijst naar environments)	MIDDEL
10	SP — SP.12 (niet-herleidbare data OTAP)	Voeg een expliciete §6 "Niet-herleidbare data per OTAP-omgeving" toe aan mini-complianceverslag.md. Beschrijf per omgeving (O/T/A/P) welke data gebruikt wordt en waarom dit niet-herleidbaar is naar productie. De pentestomgeving is al gedocumenteerd (demo-data); de andere omgevingen ontbreken.	docs/mini-complianceverslag.md (nieuwe §6)	MIDDEL
11	CR — CR.3, CR.6 (bronvermeldingen, TM-link)	(a) Voeg per bevinding een "Bronnen:"-veld toe met NVD-link of CWE-databaselink. (b) Voeg "Threat model ref:"-veld toe dat verwijst naar de STRIDE-categorie in threatmodel-v2.pdf. Kleine aanvulling met grote impact op het CR.8-niveau.	docs/pentestplan.md bevindingsblokken #1-#6	MIDDEL
12	MV — MV.6 (coverage-% per klasse)	Voeg een tabel toe met JaCoCo-coverage voor security-relevante klassen (LoginServlet, UserFormController, LogoutServlet, ChangePasswordFormController). Download het jacoco-coverage CI-artifact en noteer: klasse vóór coverage ná coverage. Dit maakt de verbetering kwantitatief aantoonbaar.	docs/validatie.md of docs/conclusie-advies.md (nieuwe §"Coverage security-klassen")	MIDDEL